Rapport Mini-SOC Wazuh

Mathias Lefebvre

Décembre 2025

Contents

1 Introduction **2**
1.1 Pourquoi ce projet ? 2

2 Architecture du Lab **3**
2.1 Description des composants 3
2.2 Réseau et isolation 4

3 Mise en place du SIEM (Wazuh) **5**
3.1 Installation du serveur Wazuh 5
3.2 Installer Wazuh Manager sur Ubuntu 5
3.3 Déploiement des Agents 6
3.3.1 Agent Windows 6
3.3.2 Agent Ubuntu 7
3.3.3 Installation via le Dashboard 7
3.4 Vérification des Agents Connectés 8

4 Types de Logs collectés **9**
4.1 Exemples de Logs et Règles Wazuh 9

5 Collecte des Logs **10**

6 Scénarios d'attaques simulés **12**
6.1 Scan Nmap (Reconnaissance) 12
6.2 Brute-Force SSH 12

7 Présentation Dashboard Wazuh Security Events **14**

8 Pistes d'améliorations **15**

9 Problèmes rencontrés **15**

10 Bilan : Ce que j'ai appris **16**

1 Introduction

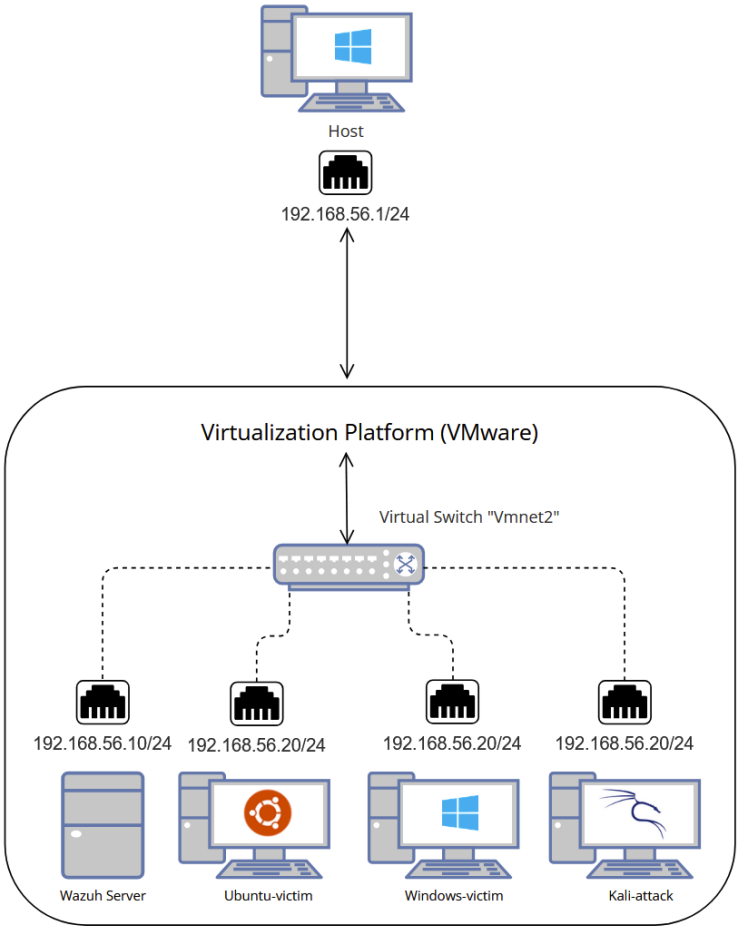
J'ai créé un mini lab SOC fonctionnel pour monter en compétence en cybersécurité. L'objectif était simple mais ambitieux. Je voulais reconstruire un environnement de détection d'attaques avec un SIEM et des VM afin de simuler les conditions d'un vrai SOC.

1.1 Pourquoi ce projet ?

Avant de viser un quelconque rôle dans le SOC, je voulais comprendre en profondeur le fonctionnement d'un SIEM comme Wazuh, mettre en place un réseau virtuel complet basé sur plusieurs machines, analyser des logs en temps réel et générer des alertes, tout en apprenant à exploiter une télémétrie système riche (incluant Sysmon, les logs SSH, activité réseau etc..).

J'ai réussi à créer un lab SOC miniature pleinement fonctionnel, capable de collecter les journaux de quatre machines (Wazuh, Windows, Ubuntu et Kali), de détecter des attaques réelles comme le brute-force, les scans réseau, de mapper les incidents aux techniques MITRE ATT&CK, et de produire des alertes contextualisées avec un niveau de sévérité exploitable.

2 Architecture du Lab



Vue d'ensemble du réseau.

2.1 Description des composants

Wazuh Server (Manager + Kibana Dashboard)

- IP : 192.168.56.10
- OS : Ubuntu Server 22.04
- Rôle : SIEM centralisé
- Composants :
  - Manager Wazuh (collecte et analyse)
  - Elasticsearch (base de données de logs)
  - Kibana (visualisation)
  - API Wazuh (gestion des agents)
- Fonction : reçoit les logs de tous les agents, déclenche des alertes et affiche le tableau de bord.

Windows 10 Victime + Sysmon

- IP : 192.168.56.30
- Rôle : machine victime générant de la télémétrie
- Outils :
  - Sysmon : capture des événements système détaillés (création de processus, connexions réseau, modifications du registre)
  - OpenSSH Server : cible pour attaque brute-force SSH
  - Wazuh Agent : envoi des logs et événements Sysmon vers le manager

Ubuntu 22.04 Victime

- IP : 192.168.56.20
- Rôle : machine Linux victime générant des logs SSH et sudo
- Outils :
  - OpenSSH : service SSH natif
  - auditd : audit système Linux
  - Wazuh Agent : collecte des logs

Kali Linux Attaquant

- IP : 192.168.56.40
- Rôle : machine attaquante simulant des menaces
- Outils :
  - Hydra : brute-force SSH
  - Nmap : scan réseau
- Attaques lancées :
  - Brute-force SSH sur Windows et Ubuntu
  - Scan réseau complet

2.2 Réseau et isolation

J'ai configuré un réseau host-only "soc-lab" en 192.168.56.0/24, sans DHCP pour utiliser uniquement des adresses IP statiques. l'ensemble du réseau est totalement isolé d'Internet. Ce choix permet de travailler dans un environnement sécurisé, où toutes les attaques générées depuis Kali restent en local. Il offre aussi une configuration reproductible sur n'importe quel PC, de meilleures performances grâce à l'absence de trafic externe, et une visibilité complète sur ce qui circule dans le lab.

3 Mise en place du SIEM (Wazuh)

3.1 Installation du serveur Wazuh

Prérequis

- Une VM Ubuntu dédiée au Wazuh Manager (ici sous ubuntu server 22.04).
- Les autres machines (Windows victime, Ubuntu victime, Kali, etc.).
- internet (temporaire ou non) pour installer les paquets

3.2 Installer Wazuh Manager sur Ubuntu

Ajouter le dépôt Wazuh

Dans la VM Ubuntu (manager) :

```
sudo apt update
sudo apt install -y curl apt-transport-https gnupg
curl -s https://packages.wazuh.com/key/GPG-KEY-WAZUH | sudo apt-key add -
echo "deb https://packages.wazuh.com/4.x/apt/ stable main" | \
  sudo tee /etc/apt/sources.list.d/wazuh.list
```

Installer le manager

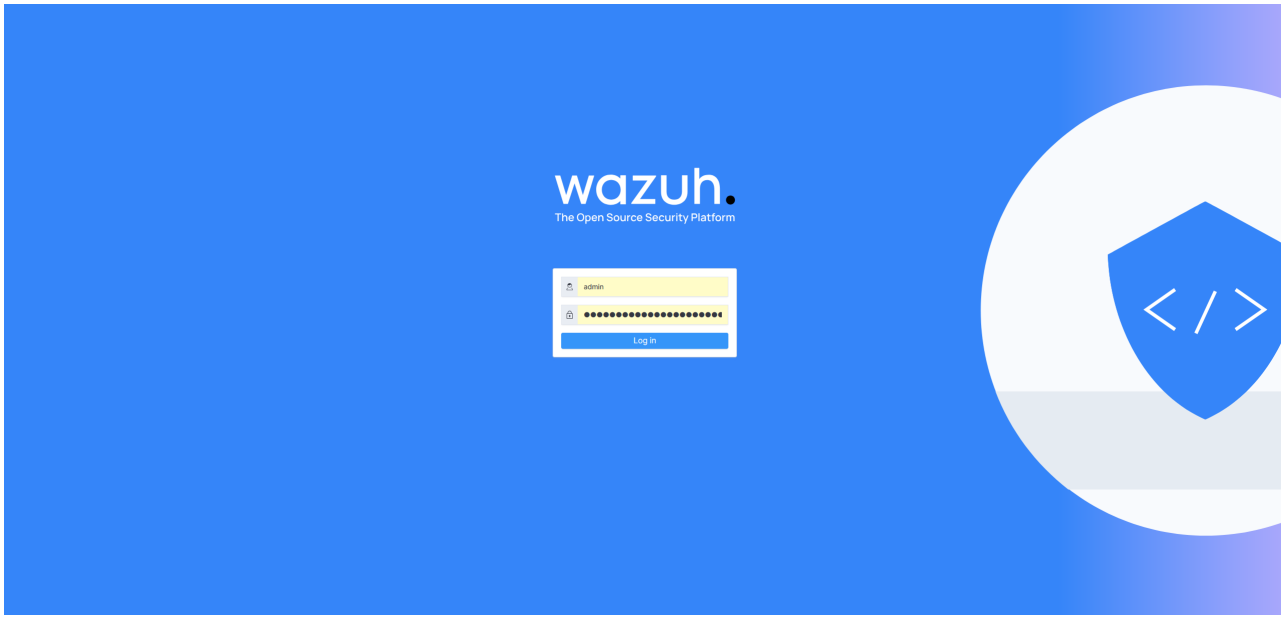
```
sudo apt update
sudo apt install -y wazuh-manager
```

Activer et démarrer le service

```
sudo systemctl enable wazuh-manager
sudo systemctl start wazuh-manager
sudo systemctl status wazuh-manager
```

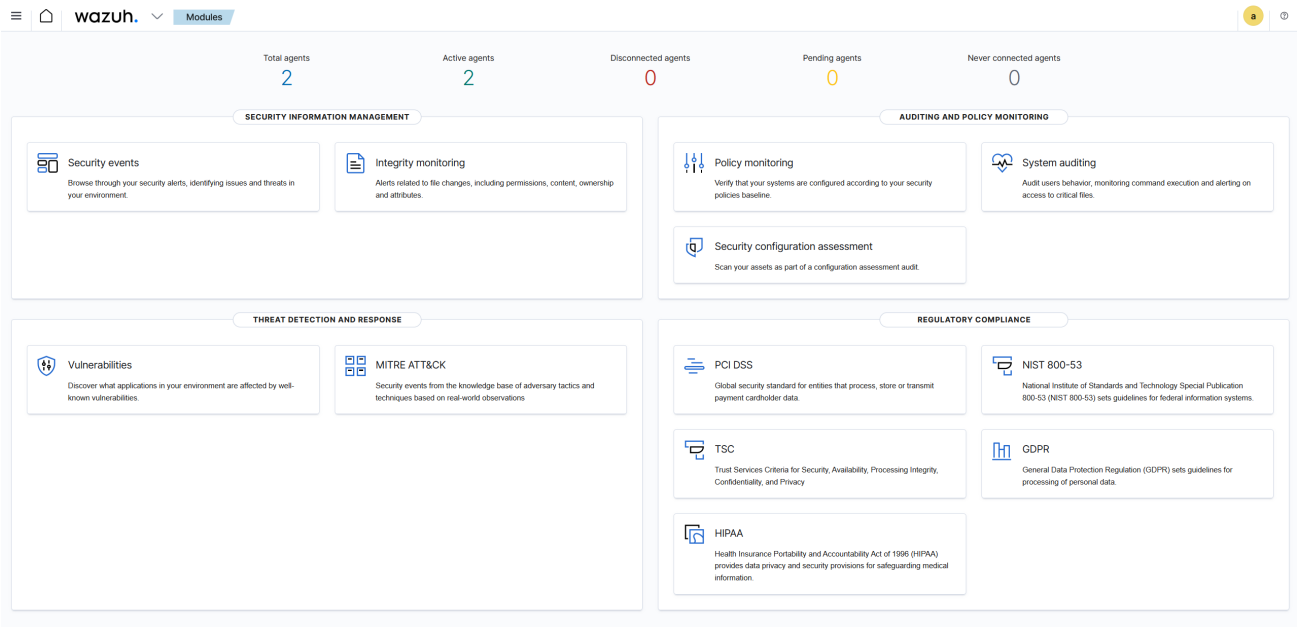
Accès au Dashboard Wazuh

```
URL : https://192.168.56.10:443
Username : admin
Password : donne lors de la config ou voir dans /var/ossec/api/configuration/authd.pass
```



Page de connexion Wazuh.

Une fois connecté, le Dashboard Wazuh est accessible via l'interface web.



Vue du Dashboard de Wazuh

3.3 Déploiement des Agents

3.3.1 Agent Windows

```
# 1. Telecharger MSI
# https://packages.wazuh.com/4.x/windows/wazuh-agent-4.7.3-1.msi

# 2. Installer (Admin)
```

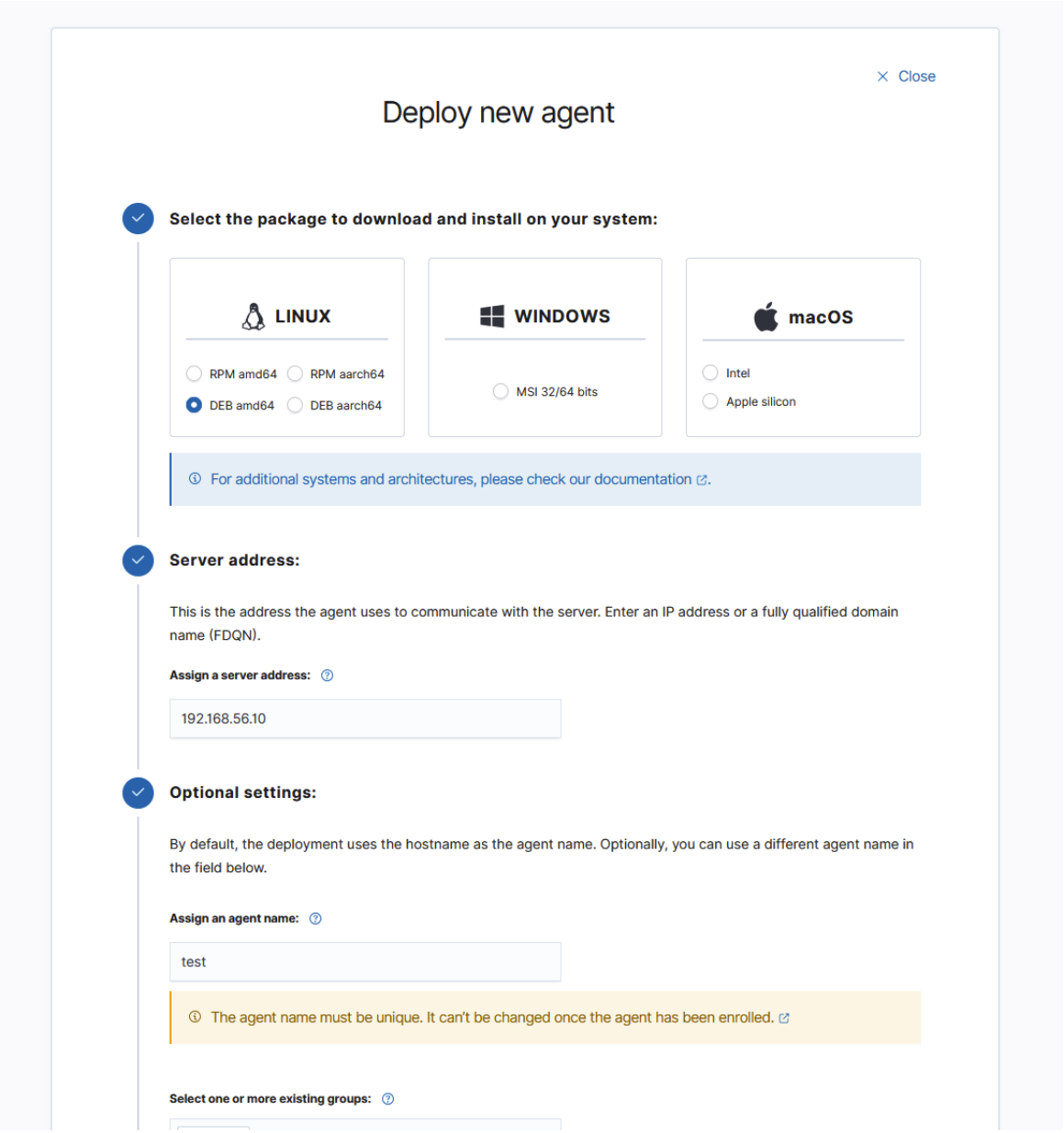
```
msiexec.exe /i wazuh-agent-4.7.3-1.msi /q MANAGER_IP="192.168.56.10"

# 3. Verifier service
Get-Service wazuh
# Status : Running

# 4. Redemarrer pour activer
Restart-Service wazuh
```

3.3.2 Agent Ubuntu

```
# 1. Ajouter cle GPG Wazuh
curl -s https://packages.wazuh.com/key/GPG-KEY-WAZUH | \
  sudo gpg --dearmor -o /usr/share/keyrings/wazuh.gpg

# 2. Ajouter depot
echo "deb [signed-by=/usr/share/keyrings/wazuh.gpg] \
  https://packages.wazuh.com/4.x/apt/ stable main" | \
  sudo tee /etc/apt/sources.list.d/wazuh.list

# 3. Installer agent
sudo apt update && sudo apt install wazuh-agent -y

# 4. Demarrer service
sudo systemctl start wazuh-agent
sudo systemctl enable wazuh-agent

# 5. Verifier
sudo systemctl status wazuh-agent
```

3.3.3 Installation via le Dashboard

Il est aussi possible de remplir via le Dashboard les informations concernant la machine et le serveur Wazuh, ce qui génère automatiquement les commandes nécessaires pour ajouter l'agent.

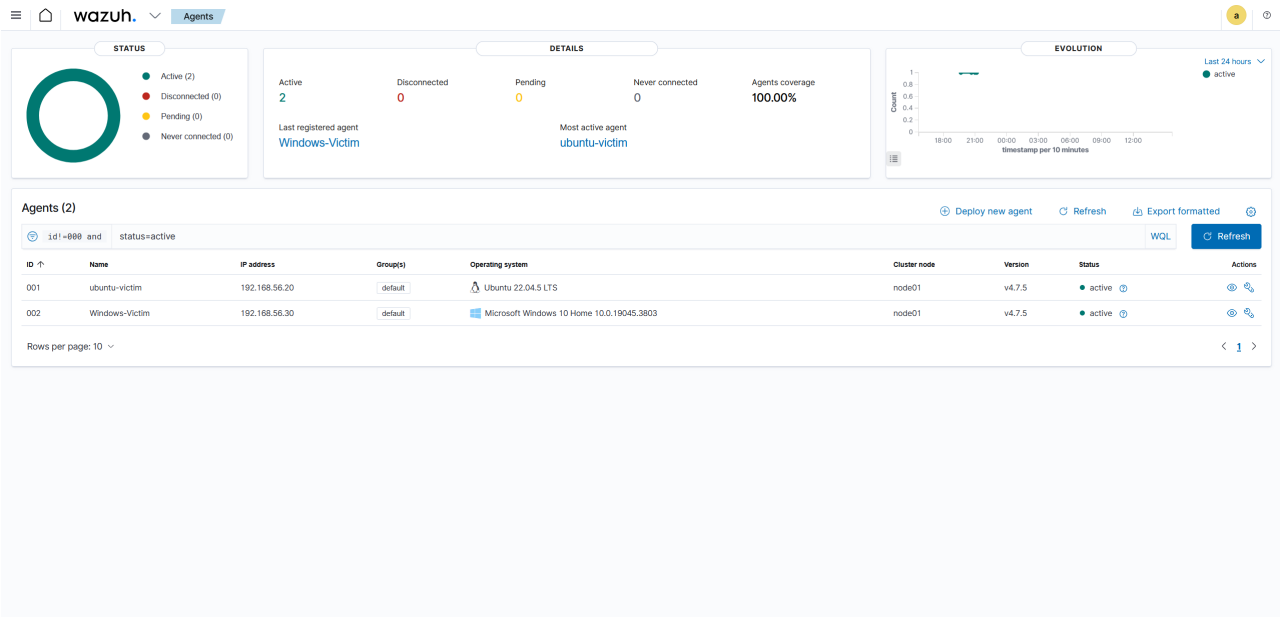


Vue de la page de déploiement des nouveaux agents du Dashboard

3.4 Vérification des Agents Connectés

Dans le Dashboard Wazuh :

```
Menu > Agents > Agents active
Attendu : 2 agents "Active" (Windows + Ubuntu)
Statut : Active
```



Vue des agents dans le Dashboard

4 Types de Logs collectés

4.1 Exemples de Logs et Règles Wazuh

Tableau des Événements Sysmon

Event ID	Type	Exemple
1	Process Creation	hydra.exe lancé
3	Network Connection	Connexion SSH vers .30:22
5	Process Terminated	Processus terminé
11	FileCreate	Fichier créé
23	FileDelete	Fichier supprimé

SSH (Ubuntu)

```
Failed password for root from 192.168.56.40 port 54321 ssh2
Invalid user attacker from 192.168.56.40 port 54322
Received disconnect from 192.168.56.40 [preauth]
```

Audit (Ubuntu)

```
type=EXECVE msg=audit(...): argc=3 a0="/bin/bash" a1="-c" a2="whoami"
type=SYSCALL msg=audit(...): arch=c000003e syscall=59 success=yes
```

Règles Activées dans Wazuh

Exemple de Configuration : /var/ossec/etc/rules/

```xml
<!-- Detection brute-force SSH -->
<rule id="5503" level="15">
  <if_sid>5502</if_sid>
  <frequency>5</frequency>
  <timeframe>60</timeframe>
  <description>SSH Brute Force Attempt</description>
  <mitre>
    <id>T1110.001</id>
  </mitre>
</rule>

<!-- Detection Sysmon Process Creation -->
<rule id="92001" level="3">
  <if_sid>92000</if_sid>
  <field name="sysmon_event_type">Process Creation</field>
  <description>Process Created</description>
</rule>

<!-- Detection command execution suspecte -->
<rule id="80002" level="10">
  <decoded_as>sysmon_process_create</decoded_as>
  <field name="ParentImage">cmd.exe</field>
  <field name="Image">powershell.exe</field>
  <description>PowerShell launched from CMD</description>
  <mitre>
    <id>T1059.001</id>
  </mitre>
</rule>
```

5 Collecte des Logs

Sysmon - Process Creation (Hydra)

```json
{
  "timestamp": "2025-12-03T20:15:32Z",
  "source": "windows-victim",
  "event_type": "Sysmon Process Creation",
  "process_name": "hydra.exe",
  "parent_process": "cmd.exe",
  "command_line": "hydra -l Administrator -P rockyou.txt ssh://192.168.56.30:22",
  "user": "DESKTOP\\Administrator",
  "process_id": 4521,
  "parent_process_id": 3412
}
```

Sysmon - Network Connection (SSH Brute Force)

```
{
```

```
  "timestamp": "2025-12-03T20:15:33Z",
  "source": "windows-victim",
  "event_type": "Sysmon Network Connection",
  "source_ip": "192.168.56.40",
  "dest_ip": "192.168.56.30",
  "dest_port": 22,
  "protocol": "TCP",
  "process": "hydra.exe",
  "connection_state": "Active"
}
```


Linux Auth.log - SSH Failed Authentication

```
Dec 3 20:15:32 ubuntu sshd[1234]: Failed password for Administrator from 192.168.56.40
    port 54321 ssh2
Dec 3 20:15:33 ubuntu sshd[1235]: Failed password for Administrator from 192.168.56.40
    port 54322 ssh2
Dec 3 20:15:34 ubuntu sshd[1236]: Failed password for Administrator from 192.168.56.40
    port 54323 ssh2
[... x 497 ...]
Dec 3 20:17:45 ubuntu sshd[1731]: Received disconnect from 192.168.56.40 [preauth]
```

Linux Audit - Command Execution

```
type=EXECVE msg=audit(1701640532.145:2891): argc=3 a0="/bin/bash" a1="-c" a2="whoami"
type=SYSCALL msg=audit(1701640532.145:2891): arch=c000003e syscall=59 exece=yes exit=0
type=UID msg=audit(1701640532.145:2891): uid=0 auid=1000 ses=5
```

Importance de la Collecte

J'ai remarqué que la collecte de données est la base d'un SOC efficace. Que sans elle, aucune détection n'est possible. Le SIEM fournit une télémétrie système détaillée sur les processus, les connexions réseau et les opérations sur les fichiers, indispensable pour repérer des comportements anormaux. Les logs réseau permettent de suivre les tentatives d'accès, les authentifications et même les commandes exécutées. En combinant ces sources, on garantit une visibilité complète : sans cela, un SOC travaille à l'aveugle.

6 Scénarios d'attaques simulés

6.1 Scan Nmap (Reconnaissance)

```
nmap -sV -p- 192.168.56.20 192.168.56.30
nmap -sS 192.168.56.20 192.168.56.30
```

Ce qui se passe : Lorsqu'une machine Kali lance un scan réseau, les machines Windows et Ubuntu reçoivent de multiples connexions entrantes. Ces tentatives sont automatiquement enregistrées par Sysmon grâce à l'Event ID 3, qui trace chaque connexion réseau. Une fois collectés, les logs sont transmis au manager Wazuh, qui identifie le motif caractéristique d'un port scanning. Dès que ce comportement est reconnu une alerte est générée.

Exemple Logs capturés

```
Source : 192.168.56.40 (Kali)
Destination : 192.168.56.20, 192.168.56.30
Ports : 1-65535 scannes
Volume : 131,000 connexions en 30 secondes
Pattern : Tous les ports testes successivement
```

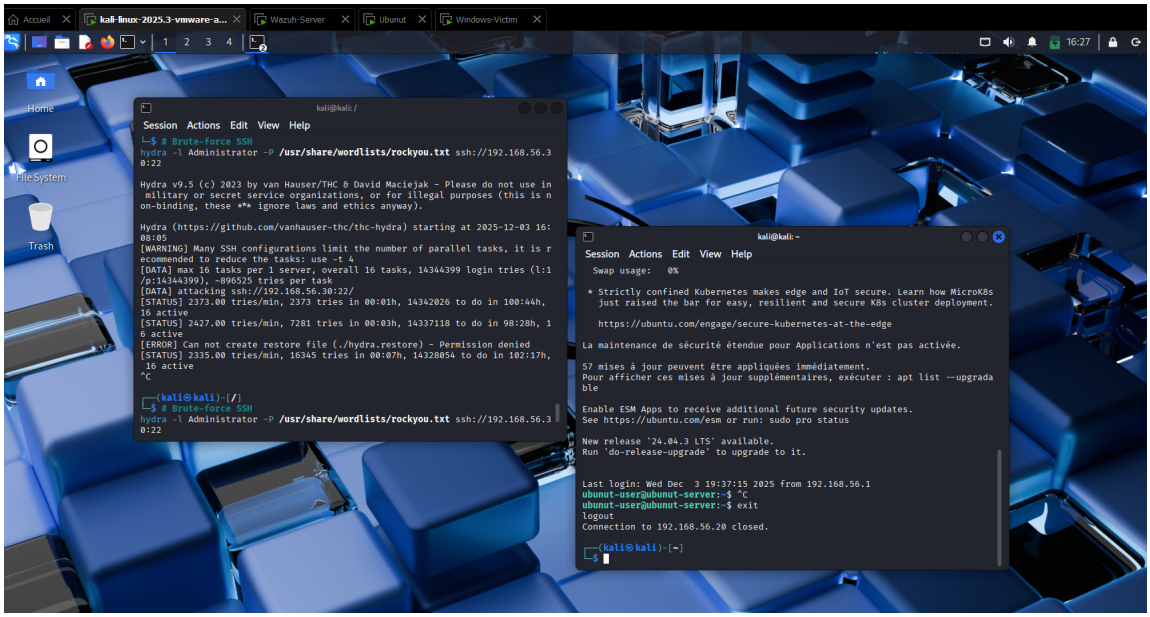
Exemple Alerte Wazuh Générée

```
[ALERT] Network Reconnaissance Activity Detected
Severity : HIGH (7/15)
MITRE ATT&CK : T1595.002 - Active Scanning
Source IP : 192.168.56.40
Destination : 192.168.56.20, 192.168.56.30
Evenements : 2,500+ connexions anormales
Recommendation : Bloquer IP source / Investigate
```

Il est d'ailleurs intéressant de remarquer que quand on fait cela, Hydra nous informe qu'un système d'observation est mis en place sur le système qu'on à voulu scanner.

6.2 Brute-Force SSH

```
hydra -l Administrator -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.30:22 -t 4 -v
hydra -l root -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.20:22 -t 4 -v
```



Bruteforce SSH depuis Kali.

Exemple Timeline Détecté

```
T+0s   : Hydra demarre (Process Creation - Event 1)
T+2s   : Premiere tentative SSH (Network Connection - Event 3)
T+5s   : 20 tentatives/seconde (SSH Failed Auth logs)
T+30s  : 500 tentatives (Still attempting)
T+60s  : 1000 tentatives (ALERT generee)
T+120s : 2000 tentatives (CRITICAL alert)
T+stop : Hydra termine (Process Terminated - Event 5)
```

Exemple Logs Sysmon

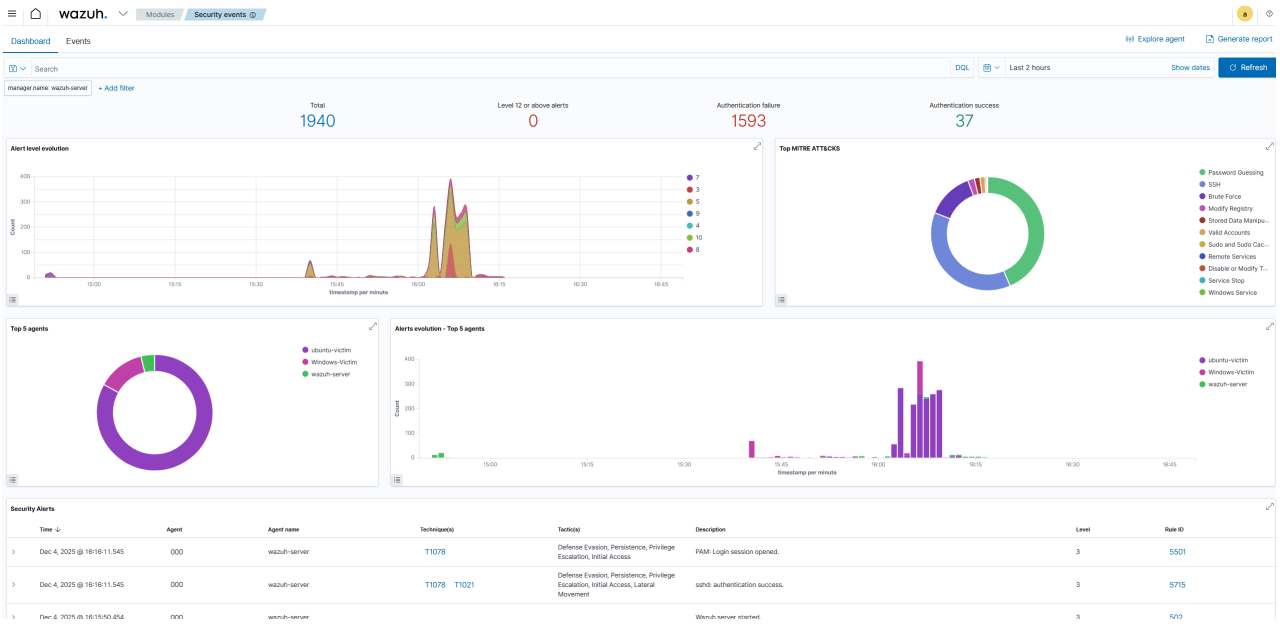
```
{
  "event_id": 1,
  "image": "hydra.exe",
  "command_line": "hydra -l Administrator -P rockyou.txt ssh://192.168.56.30:22 -t 4",
  "parent_image": "cmd.exe",
  "creation_time": "2025-12-03 20:15:00"
}
{
  "event_id": 3,
  "source_ip": "192.168.56.40",
  "destination_ip": "192.168.56.30",
  "destination_port": 22,
  "protocol": "TCP",
  "initiating_process": "hydra.exe",
  "connection_count": 2000
}
```

Logs SSH (Ubuntu)

```
Dec 3 20:15:01 ubuntu sshd[1234]: Failed password for Administrator from 192.168.56.40
Dec 3 20:15:02 ubuntu sshd[1235]: Failed password for Administrator from 192.168.56.40
Dec 3 20:15:03 ubuntu sshd[1236]: Failed password for Administrator from 192.168.56.40
[... x 1997 ...]
```

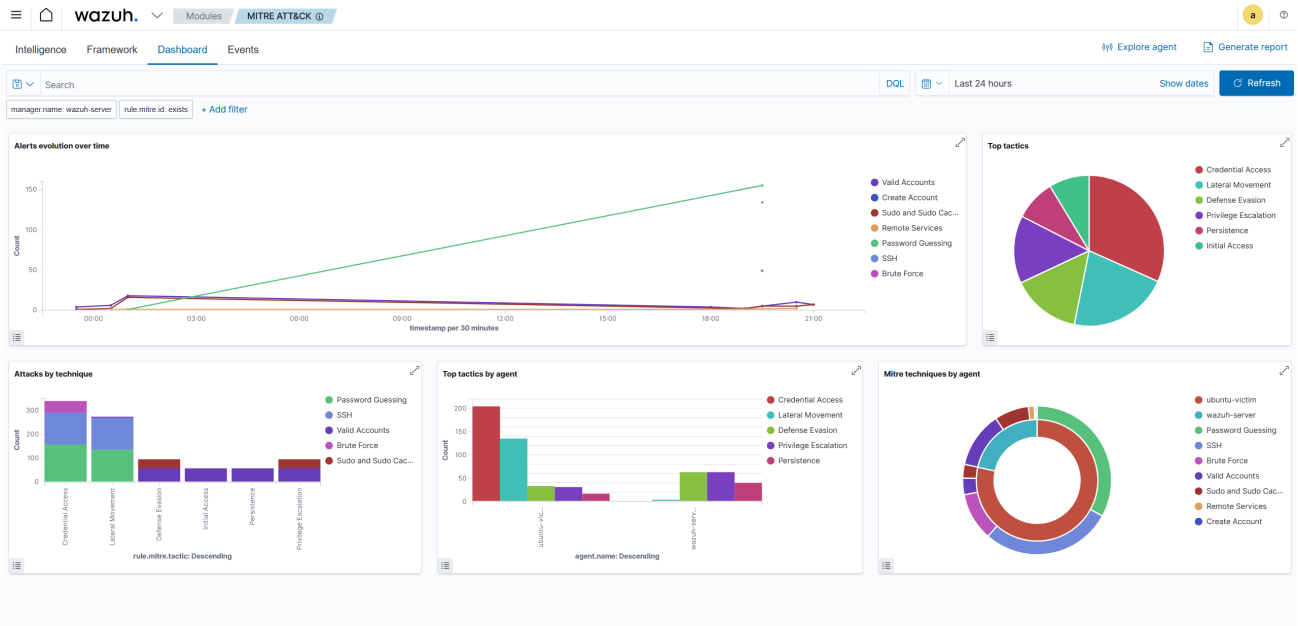
7 Présentation Dashboard Wazuh Security Events

Sur cette page du dashboard wazuh on à accès à différentes métriques clés du SOC, qui nous permet de bien voir les différents évènements levés par les différents agents



Dashboard Security Events.

On a une vision complète des événements levé par les agents grâce à la Timeline d'attaques, on observera même immédiatement les pics d'activité qui correspondent à mes différentes attaques. Chaque alerte est ensuite détaillée dans la section Security Alerts, qui fournit un rapport complet accompagné d'un niveau de sévérité qui nous permet de rapidement évaluer la gravité de l'incident.



Dashboard MITRE ATT&CK.

Enfin, l'onglet Top Detected Techniques MITRE ATT&CK qui quand on clique dessus met en évidence les techniques d'attaque identifiées et classifiées par le SIEM, offrant une lecture directe des méthodes utilisées par l'attaquant et de leur correspondance avec le framework MITRE.

8 Pistes d'améliorations

Même si je suis assez satisfait de ce que j'ai réussi à faire j'aurais aimé pouvoir intégrer un Honeypot dans ce projet. Honeypot que j'aurais installé sur une raspberry et qui aurait volontairement été vulnérable afin d'attirer les attaquants. l'idée est d'observer sans mettre en danger mon vrai système.
J'aimerai aussi ajouter un EDR Open Sources (comme Velociraptor) sur mes machines. Car la où Wazuh centralise surtout les journaux et applique des règles de corrélation, un EDR apporte une visibilité beaucoup plus fine sur les postes, voire la version ultime serait l'intégration complète d'un SOAR.

9 Problèmes rencontrés

Les principaux problèmes rencontrés durant ce projet ont été liés à la configuration de l'infrastructure et du SIEM: d'abord la mise en place du réseau VirtualBox (différence NAT / host-only, attribution d'IP statiques et connectivité fiable entre toutes les VMs), puis la communication entre les agents et le Wazuh Manager, avec des agents installés mais non vus comme "Active" à cause d'adresses de manager ou de clés d'enregistrement incorrectes. Ensuite, plusieurs difficultés sont venues du fait que les logs ne remontaient pas comme prévu: Sysmon installé mais des logs non pris en compte côté Wazuh. Il y avait aussi les pare-feu des machines Windows qui bloque la plupart des pings et/ou interaction de rentrer/sortir de la machine, ce qui m'a pris quelques temps avant de comprendre et de corriger.

10 Bilan : Ce que j'ai appris

Au cours de ce projet, la première chose apprise a été la mise en place complète d'un SIEM à partir de zéro. C'était pas forcément très simple au début car juste avec la doc c'est dur de se retrouver entre les infos et les fichiers de configurations. Mais à la fin j'ai quand même réussi à installer manuellement Wazuh, configurer le manager, les agents et vérifier la communication. Ce qui m'a permis de comprendre concrètement comment un SIEM collecte, centralise et structure les journaux d'événements au sein d'un environnement réparti.
J'ai également découvert l'importance de la télémétrie système. A quel point les événements de type création de processus, connexions réseau ou modification de fichiers sont essentiels pour reconstituer une attaque.
Le projet m'a aussi permis de faire un vrai travail """d'analyse SOC"""". (on accentue les guillemets car c'est bien plus complexe dans la vrai vie) En déclenchant moi-même des scénarios d'attaque (scan Nmap, brute-force SSH, commandes suspectes etc...).
Un autre point important a été l'architecture du lab et le réseau. La configuration du réseau host-only, la gestion des IPs statiques, l'usage combiné NAT / host-only et la place des pare-feu m'ont donné une meilleure vision de ce qu'est une architecture SOC isolée mais réaliste. J'ai compris que la détection ne repose pas seulement sur les outils, mais aussi sur la manière dont l'infrastructure est pensée pour offrir de la visibilité tout en restant sécurisée.
Enfin pour finir sur une phrase classique mais ce projet m'a appris la méthodologie et la rigueur qui je juge sont nécessaire dans un environnement SOC.

Bonne lecture pour ceux qui ont lu et merci à ceux qui le feront :)